AIORI Hackathon 3 — Proposed Project Structure

Problem Statement PS-019: Personal-Data Discovery and Privacy Evidence Inventory | Category: Cybersecurity

Project: PrivacyLens | **Deliverable:** Proposed-structure-hackathon.pdf | **Framework:** MeitY Data Protection & DPDP Act 2023

1. Executive Summary & Problem Challenge Alignment

Modern enterprise systems routinely accumulate Personally Identifiable Information (PII) across unindexed spreadsheets, operational dumps, and legacy database tables without verifiable documentation. **PrivacyLens** addresses this governance gap by implementing an automated, evidence-driven scanner that inspects synthetic CSV files and relational SQLite databases. The system identifies candidate personal-data fields across five predefined data classes, links them to declared business purpose and statutory retention metadata, and generates an auditable privacy evidence inventory for human-in-the-loop review without making automated legal compliance decisions.

2. Proposed System Architecture & Core Components

Component	Technology	Architectural Role & Scope
Frontend UI	React 18, TypeScript, Tailwind CSS, Lucide	Slate/Navy cybersecurity interface with 9 workflows: Dashboard, Data Sources, Scanner, Inventory, Metadata, Gaps, Review Center, Evaluation, and Rules.
Backend API	FastAPI, Uvicorn, Pydantic v2	High-throughput REST API with safe file ingestion, memory PII redaction, background scan execution, and export generation.
Data Connectors	CSVConnector, SQLiteConnector (Pandas)	Read-only URI connection mode (mode=ro), schema inspection, non-null sampling, and memory protection (MAX_SAMPLE_ROWS).
Detection Engine	RulesEngine, ScannerEngine, PyYAML	Multi-signal scoring: Column header regex (W_col), Value pattern match ratio (W_val), and format/plausibility validators (W_fmt).
Evidence Register	MetadataManager, SQLite (privacylens.db)	Tri-part compound mapping (dataset, table, column) preventing ambiguous assignments, flagging missing purpose/retention.
Evaluation Unit	AccuracyEvaluator, Scikit-Learn standard	Transparent benchmark scoring on labelled test set (50+ samples) calculating TP, FP, FN, Precision, Recall, and F1.

3. Predefined Five Personal Data Classes & Configurable Rules

Data Class	Header Signals & Negative Controls	Value Syntax & Format Validators
1. Person Name	Regex: first_name, last_name, cust_name, etc. Negative: company_name, product_name, file_name	Multi-word alphabetic regex, alphabetic density > 75%, character length boundaries (2-60 chars).
2. Email Address	Regex: email, work_email, contact_email Negative: mailbox_id, mailer_daemon, template	RFC-compliant email pattern, single @ symbol check, valid TLD segment length >= 2.
3. Phone Number	Regex: phone, mobile, contact_no, tel_no Negative: imei, ip_address, serial, order_no, zip_code	Indian 10-digit mobile (+91/0 starting 6-9) & E.164 formats, non-digit stripping, repetitive dummy filter.
4. Government ID	Regex: aadhaar, uidai, pan, ssn, gov_id Negative: session_id, uuid, transaction_id, order_id	Aadhaar 12-digit format (cannot start with 0/1), Indian PAN (5 letters, 4 digits, 1 letter), US SSN format.
5. Date of Birth	Regex: dob, date_of_birth, birth_date Negative: created_at, updated_at, order_date, timestamp	ISO/standard date parsing, age plausibility check (0 to 125 years), automatic rejection of future dates.

4. Multi-Signal Detection Algorithm Pseudocode (Mentor Deliverable)

```
ALGORITHM ScanColumnForPersonalData(col_name, sample_vals, rules):
best_candidate = NULL, max_conf = 0.0
FOR EACH (class_name, class_def) IN rules.classes:
// 1. Column Signal (with explicit negative suppression)
matched_col = AnyRegexMatch(class_def.column_patterns, col_name)
neg_col = AnyRegexMatch(class_def.negative_column_patterns, col_name)
col_score = 0.0 IF neg_col ELSE (1.0 IF matched_col ELSE 0.0)
// 2. Sample Value Match Ratio
matched_vals = CountMatching(class_def.value_patterns, sample_vals)
val_ratio = matched_vals / Length(sample_vals) IF sample_vals ELSE 0.0
// 3. Domain Format & Plausibility Validation
valid_count = CountValid(class_def.validator, sample_vals)
fmt_ratio = valid_count / Length(sample_vals) IF sample_vals ELSE 0.0
// 4. Weighted Confidence Combination
conf = (col_score * W_col) + (val_ratio * W_val) + (fmt_ratio * W_fmt)
IF conf >= rules.threshold AND conf > max_conf:
max_conf = conf, best_candidate = Candidate(class_name, conf, MaskSample(sample_vals))
RETURN best_candidate
```

5. Metadata Mapping, Evidence Gap Detection & Audit Exports

To satisfy the core requirement of linking fields to purpose and retention without legal guesswork:
• **Compound Key Matching:** Exact triple resolution (dataset_name, table_name, column_name) resolves ambiguity when common column names (e.g. id or email) appear across different tables.
• **Gap Classification:** Detections are automatically audited against declared registries and flagged with states: *Complete metadata*, *Missing purpose*, *Missing retention*, *Missing both*, or *Ambiguous match*.
• **Human-in-the-Loop Review:** Security analysts and DPOs can confirm or reject candidate detections, log audit notes, and download structured CSV and printable PDF inventory reports.

6. Benchmark Evaluation & Precision / Recall Metrics

PrivacyLens includes a synthetic benchmark dataset (sample_data/labelled_test_set.csv) containing over 50 ground-truth annotated fields across all 5 classes as well as non-personal negative controls (e.g. created_at, quantity, company_name). The automated evaluation engine computes True Positives (TP), False Positives (FP), False Negatives (FN), True Negatives (TN), per-class Precision, Recall, and F1 scores, and Macro Averages in compliance with standard Scikit-Learn evaluation protocols.

7. Technical Evidence vs. Legal Interpretation Boundary

Important Technical & Legal Disclaimer (AIORI PS-019 Requirement):
PrivacyLens is an engineering discovery tool that produces transparent technical evidence for human review. In strict adherence to the problem statement requirements, the system DOES NOT make automatic lawful-basis determinations, infer universal cross-system data flows, or provide automated statutory compliance certificates under the DPDP Act 2023 or GDPR. All candidate detections and metadata gaps require validation by qualified human privacy professionals or Data Protection Officers (DPOs).